Segurança de Dados

MCTA023-17

Integridade e Autenticidade de Mensagem

Profª Denise Goya

Roteiro

- Criptografia e
  - Integridade: hash criptográfico
  - Autenticidade de mensagem: MAC

Criptografia Simétrica e Integridade

Criptografia e Integridade

Como detectar **alterações** em dados ou mensagens?

Uma primeira resposta:

- códigos de detecção de erros (CRC e outros)
- restrições: muito fracos contra adversários que tentam **adulterar** dados ou mensagens

Para aplicações em segurança:

- **funções de Hash criptográficas** fornecem propriedades mais adequadas

Algoritmos Auxiliares:

Funções de Hash

Algoritmos Auxiliares

Hash

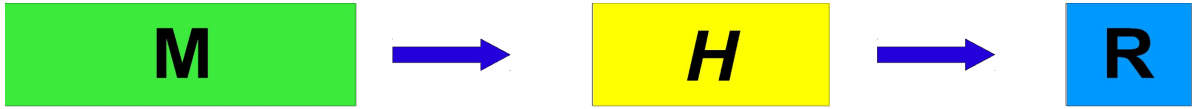
- para integridade de dados
- auxiliar também para assinaturas digitais (autenticidade, integridade e irretratabilidade)

MAC

- código de autenticação (sem irretratabilidade)

Algoritmo de Hash

- Message Digest – Resumo de Mensagem
- Função matemática que toma uma mensagem de tamanho arbitrário e calcula um número de tamanho fixo (por ex. entre 128 e 160 bits)
- Só depende da mensagem (sem chave)



- Mensagem original é anexada com sua função de hash, para detectar alterações

Função Hash

Função que:

- Dado um texto **x** relativamente longo (algumas centenas de bytes, por exemplo)
- Produz um **resumo y** com tamanho bem menor (algo como 128 bits, por exemplo)

$$H(x) = y$$

- Note de **não** depende de chave, depende exclusivamente da mensagem **x**

Função Hash - Propriedades

É importante que H tenha as propriedades:

- resistência à **primeira inversão**:
  - dado um resumo y, seja inviável encontrar uma mensagem x tal que H(x) = y
- resistência à **segunda inversão**:
  - dados um resumo y e uma mensagem x, seja inviável encontrar uma segunda mensagem x'≠x tal que H(x') = y
- resistência a **colisões**:
  - é inviável encontrar duas mensagens x'≠x, tais que H(x') = H(x)

Função Hash - Propriedades

Mais propriedades desejáveis:

- A alteração de 1 bit da entrada causa a alteração de cerca de metade dos bits de saída (efeito **avalanche**)
- É inviável prever o valor de qualquer bit de saída (**indistinguibilidade**)
- É inviável inverter a função parcialmente (recuperar apenas alguns bits da entrada)

Hash na Prática

O remetente envia

- uma mensagem x, junto com o respectivo hash calculado H(x)

O destinatário

- recebe a mensagem e o hash
- calcula o hash sobre a mensagem recebida
- compara o hash recebido com o calculado
- se houver diferença, houve alterações (erros na transmissão ou adulteração do original)

Detecção de alterações: objetivo do serviço de **integridade**

Hash na Prática, Alternativamente

Arquivos de um sistema

- têm o hash calculado e armazenado
- para se verificar a **integridade** dos arquivos originais, recalcula-se o hash e compara com o armazenado
- se houver diferença, houve alterações

Algumas aplicações:

- antivírus
- identificação de arquivos duplicados
- perícia criminal (cadeia de custódia, busca de arquivos suspeitos)

Hash na Prática, Alternativamente

Login em sistemas

- é muito comum que a senha de usuário (texto alfa-numérico) seja convertida para algo mais “confuso” (com alta entropia, como uma string binária aparentemente aleatória), para aumentar o nível de segurança
- hash é opção comum para essa conversão

Voltando às Propriedades Básicas

Exemplos que justificam as propriedades básicas:

resistência à **primeira inversão**:

- se alguém conseguiu o hash de uma senha, é desejável que ele não consiga obter a senha

resistência à **segunda inversão**:

- dado um contrato assinado digitalmente (com hash), é desejável que não seja possível encontrar outra mensagem diferente (muito menos outro contrato) com mesmo valor de hash

resistência a **colisões**:

- se conteúdos foram substituídos, as alterações devem ser detectáveis

Algoritmos de Hash

Família MD (Message Digest)

- MD2, MD4 e MD5
- Desenvolvido por Ron Rivest no MIT
- **Hoje completamente quebrados:**
  - **a família inteira é insegura!**

MD5 ainda persiste em muitas aplicações

Algoritmos de Hash

Família **SHA** (Secure Hash Algorithm)

- Desenvolvido pelo NIST (National Institute of Standards and Technology) e publicado como norma em 1993.
- SHA-0 e SHA-1, projetos inspirados no MD4
  - ambos quebrados
- SHA-2, família de variantes que agrupam:
  - SHA-224, SHA-256, SHA-384 e SHA-512
  - futuro incerto: não se sabe até quando resistirão, pois os projetos basicamente seguem os mesmos paradigmas dos já comprovados inseguros

Ponto Fraco

As funções de Hash conhecidas até SHA-xx

- basicamente dependem de uma **função de compressão** que é iterada várias vezes
- a função de compressão deve ser computacionalmente livre de colisões (Damgard89)
- ponto fraco nos projetos SHA-0 e SHA-1: **função de compressão**
- aparentemente com o SHA-2 ocorre o mesmo
- é necessário: **mudança de paradigma**

Hash: SHA3

NIST promoveu novo concurso para Hash

Advanced Hash Standard (AHS)

Encerrado em outubro de 2012:

vencedor: Keccak

Baseado em função esponja criptográfica (novo paradigma de construção)

- tema de um dos seminários

Trabalho em Equipes: Escolha dos Temas e Datas

Segurança de Dados - Temas e Equipes dos Trabalhos

Para editar, faça login UFABC no Google

			Nome e Sobrenome	Situação	Turma	Contato
G1	**Software malicioso (G1)**					
	Tópicos obrigatórios:	1				
	Tipos e Funcionamento	2				
	Técnicas de Detecção e Defesas (estáticas e dinâmicas)	3				
	Referências principais:	4				
	Aslan, Ö. A. and Samet, R. "A Comprehensive Review on Malware Detection Approaches," in IEEE Access, vol. 8, pp. 6249-6271, 2020, doi: 10.1109/ACCESS.2019.2963724.	5				
	W. Stallings and L. Brown, Computer Security: Principles and Practice, 4ed.:Pearson Education, 2018.	.				
		.				
G2	**Ataques de negação de serviço (G2)**		**Nom**			
	Tópicos obrigatórios:	1				
	DoS e DDoS (Tipos e Funcionamento)	2				
	Técnicas de Prevenção e Detecção	3				
	Defesas e respostas contra DoS e DDoS	4				
	Referências principais:	5				
	Laufer, R. P., Moraes, I. M., Velloso, P. B., Bicudo, M. D., Campista, M. E. M., Cunha, D. d. O., Costa, L., and Duarte, O. (2005). Negação de serviço: Ataques e contramedidas. Livro Texto dos Mini-cursos do V Simpósio Brasileiro de Segurança da Informação e de Sistemas	.				

Apresentações (20 a 30 minutos por grupo)
2 a 3 grupos por data
aloque seu grupo em uma data após combinar com todos integrantes
todas as apresentações acontecem na sala de aula (Teoria)

Datas	**Grupos** (use a numeração G1 a G20)		
24/mar.			
31/mar.			
2/abr.			
7/abr.			
9/abr.			
14/abr.			
16/abr.			

Escolham a data de apresentação

+ ≡ temas cronograma

Criptografia Simétrica e Autenticidade de Mensagem

Autenticidade de Mensagem

Cifras simétricas (de **chave secreta**) conferem autenticidade de forma simples:

- o emissor e o receptor são autenticados, pois conhecem a chave secreta **compartilhada**

Esta forma simplificada de se autenticar pode ser obtida também com **códigos de autenticação**

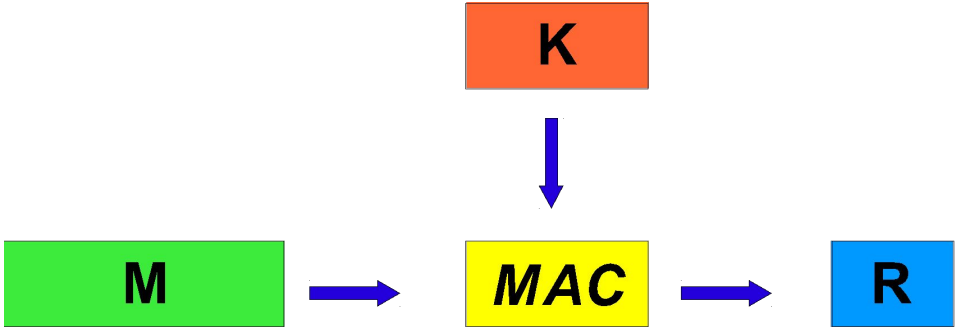
Códigos de autenticação (MAC) objetivam:

- autenticação
- integridade

MAC – Código de Autenticação de Msg

Valor calculado em função da mensagem de uma **chave secreta** compartilhada

O valor é anexado à mensagem, como informação redundante que, quando conferida, indica autenticidade e integridade



MAC – Código de Autenticação de Msg

MAC não garante irretratabilidade

- pois a chave secreta é compartilhada (conhecida por mais de uma entidade)

MAC – Código de Autenticação de Msg

MAC pode ser construído a partir de:

- Cifras de bloco, com os modos de operação
  - CBCMAC
  - CMAC
  - GMAC (baseado no modo de operação GCM)

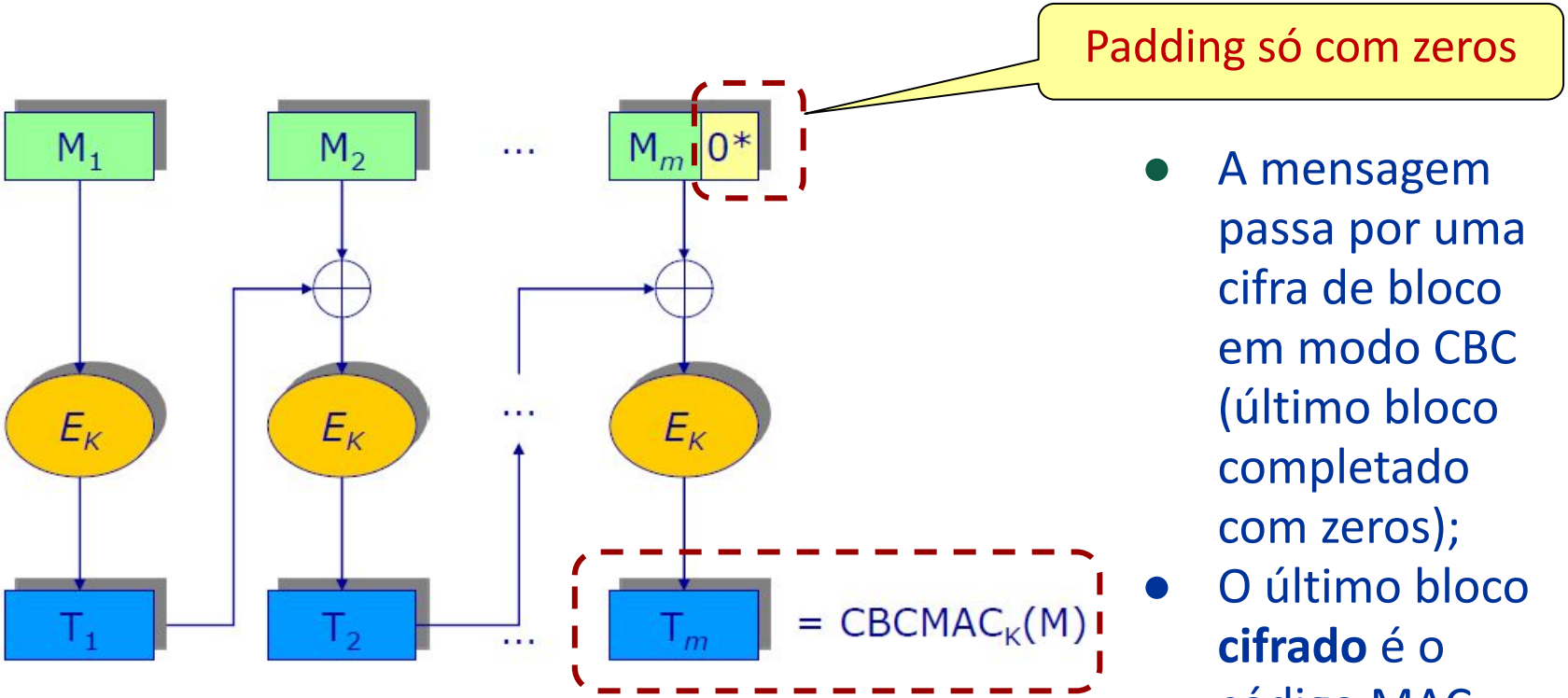
- Funções de Hash:
  - HMAC

MAC com Cifras de Bloco

Mensagens de tamanho arbitrário são divididas em blocos de tamanho fixo sobre os quais é aplicada a cifra com chave secreta

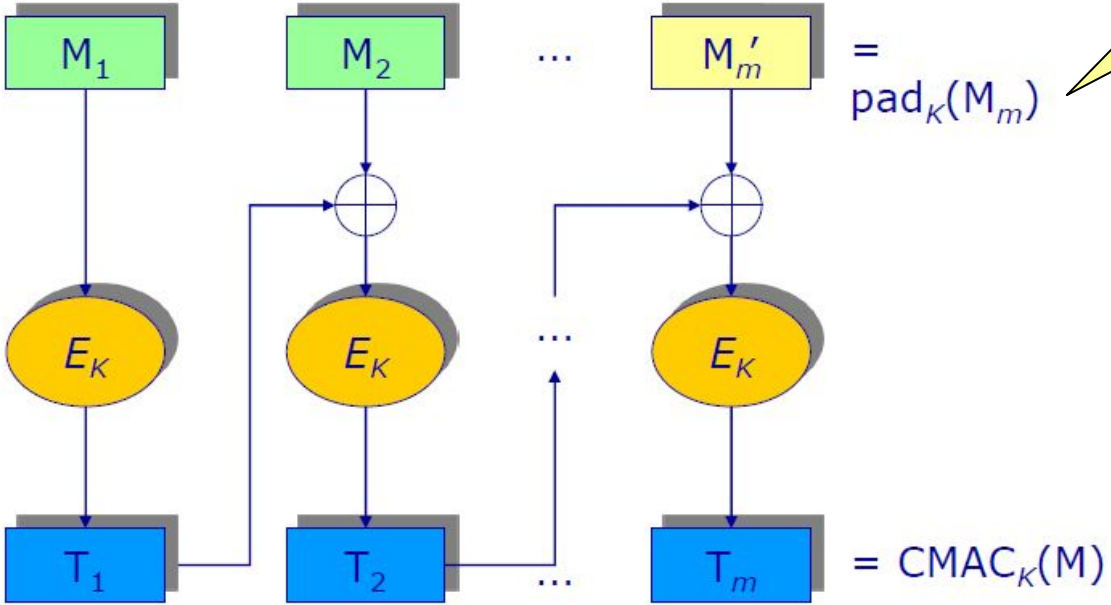
- resultado de cada bloco cifrado é encadeado (por meio de XOR) com o próximo bloco
- Útil para reaproveitar circuitos já prontos
- GMAC é o mais eficiente e padrão desde 2007
- CMAC e CBCMAC se diferenciam pelo padding:
  - CBCMAC é seguro só sobre certos tamanhos de msgs
  - CMAC pode ser aplicado a mensagens de qualquer tamanho

MAC com CBCMAC



- A mensagem passa por uma cifra de bloco em modo CBC (último bloco completado com zeros);
- O último bloco **cifrado** é o código MAC

MAC com CMAC



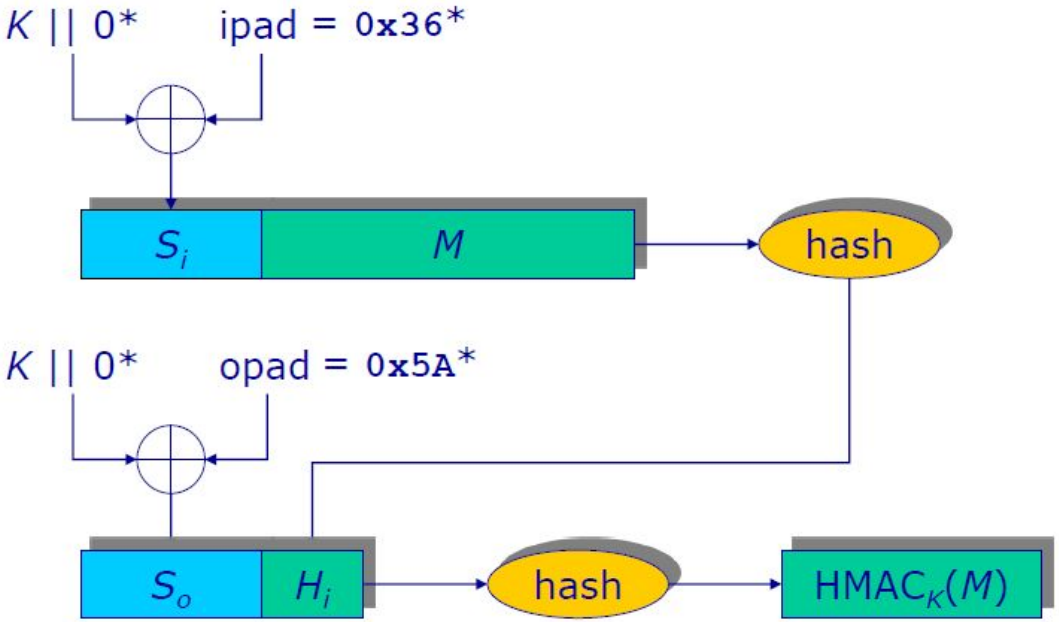
Padding dependente da chave *K*

- Análogo ao CBCMAC, mas o último bloco é preenchido com valor dependente da chave e da mensagem
- O último bloco **cifrado** é o código MAC

MAC com Funções Hash: HMAC

- uma função de Hash escolhida é aplicada duas vezes

- são criados dois blocos dependentes da chave, para compor com a mensagem antes de aplicar o hash, nas duas vezes



O que vimos até agora

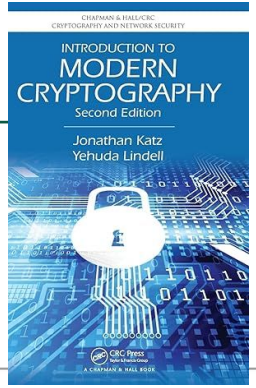
Ferramentas criptográficas para:

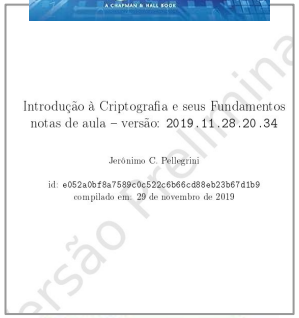
- **confidencialidade**
  - cifras de fluxo e de bloco
- **integridade**
  - hash criptográfico
- **autenticidade**
  - códigos de autenticação

Estudo Individual

Leituras Sugeridas

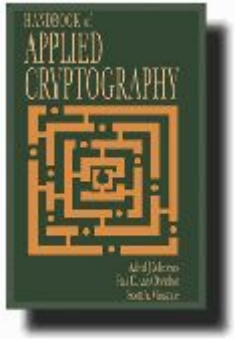
- Jonathan Katz, Yehuda Lindell. Introduction to Modern Cryptography, Second Edition. CRC Press. 2014.
- Jerônimo C. Pellegrini, Introdução a Criptografia e seus Fundamentos - Notas de aula - versão preliminar, Capítulos 7 e 8. (2019), disponível em http://aleph0.info/cursos/ic/notas/
- Alfred J. Menezes, Paul C. van Oorschot and Scott A. Vanstone, Handbook of Applied Cryptography, Capítulo 8. CRC Press (1996), disponível em http://cacr.uwaterloo.ca/hac/




Introdução à Criptografia e seus Fundamentos
notas de aula – versão: 2019.11.28.20.34

Jerônimo C. Pellegrini

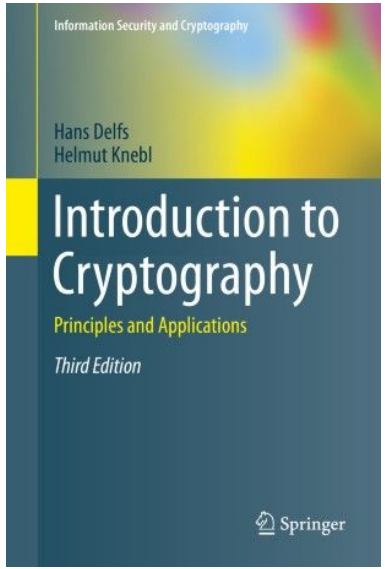
id: e052a0bf8a7589c0c522c6b66cd88eb23b67d1b9
compilado em: 29 de novembro de 2019



Outras Leituras

Tutorial para acesso a Livros via Cafe Capes, com login institucional UFABC:

https://portal.biblioteca.ufabc.edu.br/images/docs/Orientacoes_para_o_acesso_remoto_via_CAFe.pdf



Logado, acesse:

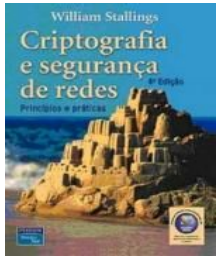
https://link-springer-com.ez42.periodicos.capes.gov.br/book/10.1007/978-3-662-47974-2

e leia Capítulo 2 de

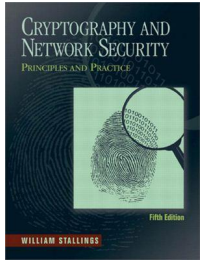
Hans Delfs, Helmut Knebl. Introduction to Cryptography Principles and Applications, Springer (2015)

Outras Leituras

- Stallings, W. Criptografia e segurança de redes – Princípios e Práticas, 4 edição, ed Prentice Hall.



- Stallings, W. Cryptography and Network Security: Principles and Practice, 5.ed. Prentice Hall.



Questões de Autoavaliação

(não precisa entregar)

Exercícios

1. Por que códigos de detecção de erros, como CRC, não podem ser usados para garantia de integridade? Que propriedades as funções criptográficas de hash possuem que não estão presentes em códigos de detecção de erros?
2. Explique porque códigos de autenticação (MAC) podem garantir autenticidade de mensagens. Por que não garantem irretratabilidade?
3. Consulte a especificação do modo de operação GCM e o respectivo MAC associado GMAC em http://nvlpubs.nist.gov/nistpubs/Legacy/SP/nistspecialpublication800-38d.pdf. Resuma seu funcionamento.